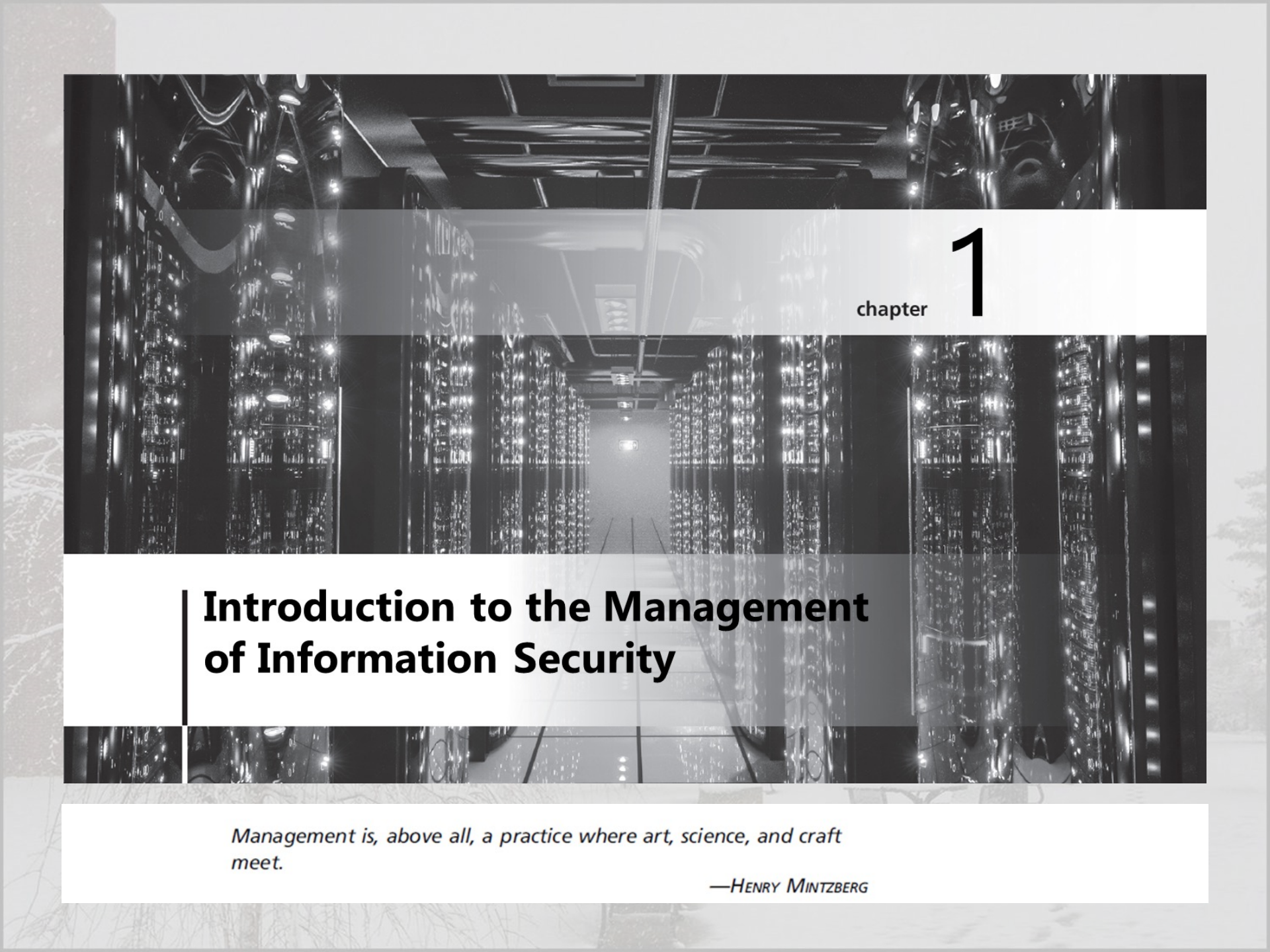




chapter 1

Introduction to the Management of Information Security

Management is, above all, a practice where art, science, and craft meet.

—HENRY MINTZBERG

Mục tiêu chương học

- Hoàn thành chương này, sinh viên có thể:
 - Mô tả tầm quan trọng của vai trò nhà quản lý trong bảo đảm an toàn của tổ chức sử dụng công nghệ thông tin
 - Liệt kê và thảo luận các đặc tính cơ bản của an toàn thông tin
 - Liệt kê và mô tả các mối đe dọa chính đối với an toàn thông tin
 - Thảo luận về các đặc điểm chính của lãnh đạo và quản lý (leadership and management)
 - Phân biệt quản lý bảo mật thông tin với quản lý kinh doanh chung

The background of the slide features a faded image of a modern, multi-story building with a curved facade and large windows. In the foreground, there is a park-like setting with a prominent weeping willow tree on the left, several outdoor tables and chairs, and a paved path leading into the distance. The overall tone is light and professional.

Chương 01: Giới thiệu về Quản lý An toàn Thông tin

GIỚI THIỆU QUẢN LÝ AN TOÀN THÔNG TIN



Case Opener

One month into her new position at Random Widget Works, Inc. (RWW), Iris Majwubu left her office early one afternoon to attend a meeting of the local chapter of the Information Systems Security Association (ISSA). She had recently been promoted from her previous assignment at RWW as manager of information risk to become the first chief information security officer (CISO) to be named at RWW.

This occasion marked Iris's first ISSA meeting. With a mountain of pressing matters on her cluttered desk, Iris wasn't exactly certain why she was making it a priority to attend this meeting. She sighed. Since her early morning wake-up, she had spent many

hours in business meetings, followed by long hours at her desk working toward defining her new position at the company.

At the ISSA meeting, Iris saw Charlie Moody, her supervisor from Sequential Label and Supply (SLS), the company she used to work for. Charlie had been promoted to chief information officer (CIO) of SLS almost a year ago.

"Hi, Charlie," she said.

"Hello, Iris," Charlie said, shaking her hand. "Congratulations on your promotion. How are things going in your new position?"

"So far," she replied, "things are going well—I think."

Charlie noticed Iris's hesitancy. "You think?" he said. "Okay, tell me what's going on."

"Well, I'm struggling to get a consensus from the senior management team about the problems we have," Iris explained. "I'm told that information security is a priority, but everything is in disarray. Any ideas that I bring up are chopped to bits before they're even taken up by senior management. There's no established policy covering our information security needs, and it seems that we have little hope of getting one approved anytime soon. The information security budget covers my salary plus a little bit of funding that goes toward part of one position for a technician in the network department. The IT managers act like I'm wasting their time, and they don't seem to take our security issues as seriously as I do. It's like trying to drive a herd of cats!"

Charlie thought for a moment and then said, "I've got some ideas that may help. We should talk more, but not now; the meeting is about to start. Here's my new number—call me tomorrow and we'll get together for coffee."

Giới thiệu

- Công nghệ thông tin (IT) có thể ví là một cỗ xe chứa và chuyên chở thông tin thông tin từ một doanh nghiệp đến các nơi khác
 - Điều gì xảy ra nếu chiếc xe bị vỡ?
- Theo thời gian, khái niệm bảo mật / an toàn máy tính được thay thế bởi khái niệm bảo mật/an toàn thông tin
- **An toàn thông tin** không còn là trách nhiệm duy nhất của một vài người hoặc nhóm trong công ty; mà đúng hơn là **trách nhiệm của mọi nhân viên, đặc biệt là các nhà quản lý.**

Giới thiệu

- Các tổ chức phải nhận thức rằng các quyết định an toàn thông tin cần có sự tham gia của ba nhóm các nhà quản lý và chuyên gia riêng biệt, hoặc các cộng đồng có cùng mối quan tâm:
 - Những người trong lĩnh vực an toàn thông tin (ATTT)
 - Những người trong lĩnh vực CNTT
 - Những người còn lại trong tổ chức

Các cộng đồng cùng mối quan tâm

- ATTT: bảo vệ các tài sản thông tin của tổ chức từ nhiều đe dọa mà họ phải đối mặt
- CNTT: hỗ trợ các mục tiêu kinh doanh của tổ chức bằng cách cung cấp và hỗ trợ CNTT phù hợp với các yêu cầu kinh doanh
- Kinh doanh nói chung: nêu rõ và truyền đạt chính sách, mục tiêu của tổ chức và phân bổ nguồn lực cho các nhóm khác

Bảo mật là gì?

- Để hiểu các khía cạnh kỹ thuật của an toàn thông tin, bạn phải biết định nghĩa của các thuật ngữ và các khái niệm CNTT
- Nói chung, bảo mật được định nghĩa là “không bị nguy hiểm”. An toàn là được bảo vệ khỏi rủi ro mất mát, hư hỏng, thay đổi không mong muốn hoặc các mối nguy khác
- Bảo mật thường đạt được bằng một số chiến lược được thực hiện đồng thời hoặc được sử dụng kết hợp với nhau
- Vai trò của quản lý là đảm bảo rằng các chiến lược an toàn được hoạch định, tổ chức, biên chế, chỉ đạo và kiểm soát một cách hợp lý.

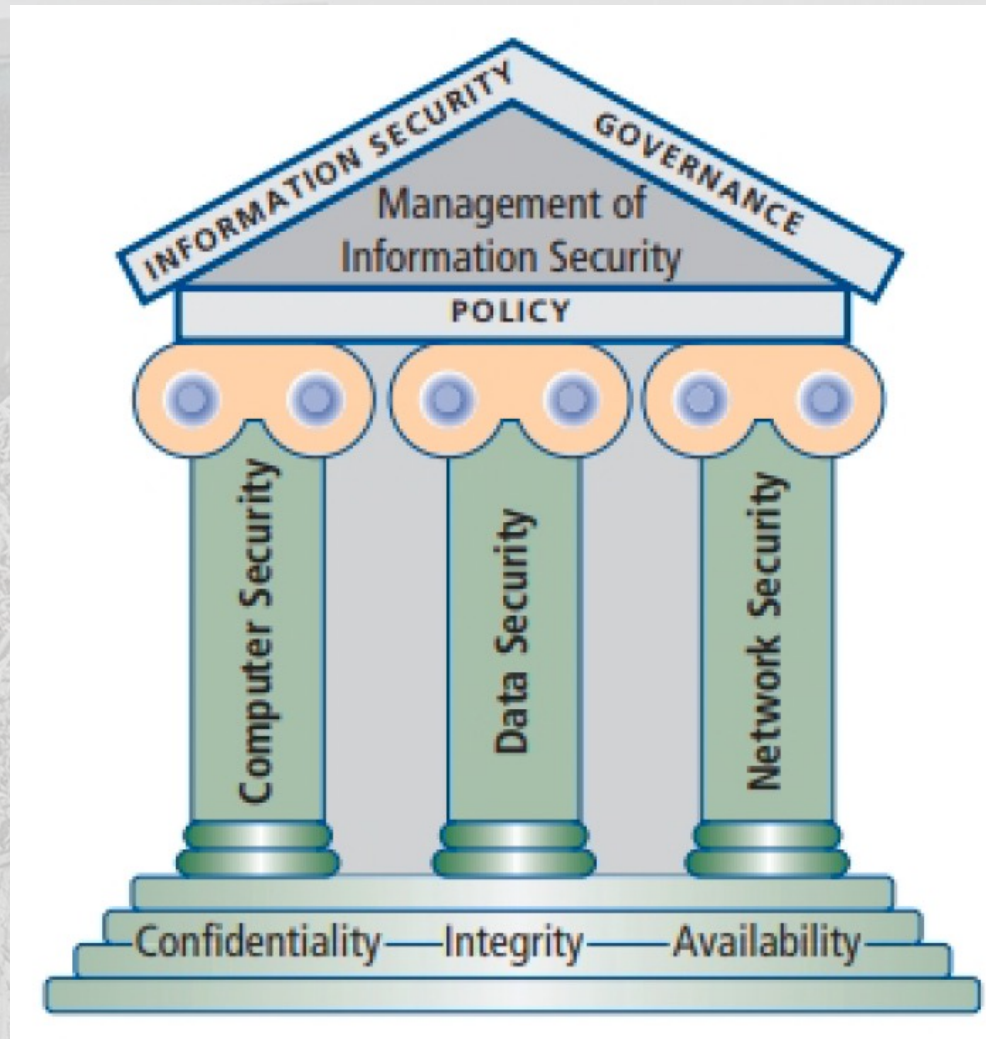
Các lĩnh vực bảo mật chuyên biệt

- Bảo mật vật lý
- Bảo mật vận hành
- Bảo mật truyền thông
- Bảo mật không gian (hoặc máy tính)
- Bảo mật mạng

An toàn thông tin

- An toàn thông tin (InfoSec) tập trung vào việc bảo vệ thông tin và các đặc điểm mang lại giá trị cho thông tin như tính bảo mật, tính toàn vẹn và tính khả dụng, và bao gồm lưu trữ và chuyển giao thông tin đó qua nhiều cơ chế bảo vệ như chính sách, chương trình đào tạo và nâng cao nhận thức, và công nghệ

Các thành phần của An toàn Thông tin



Tam giác CIA và mô hình CNSS

- Tam giác C.I.A. - tính bảo mật, tính toàn vẹn và tính khả dụng - đã được mở rộng thành một danh sách toàn diện hơn về các đặc tính quan trọng của thông tin
- Mô hình bảo mật NSTISSI (hoặc CNSS) (còn được biết đến với tên Khối lập phương McCumber) cung cấp góc độ chi tiết hơn về bảo mật
- Mặc dù mô hình NSTISSC bao gồm ba khía cạnh của an toàn thông tin, nhưng mô hình này bỏ qua thảo luận về các hướng dẫn và chính sách chi tiết dẫn dắt việc thực hiện các biện pháp kiểm soát
- Một điểm yếu khác của việc sử dụng mô hình này với cách tiếp cận khá hạn chế là xem nó từ một góc độ duy nhất

Mô hình bảo mật CNSS

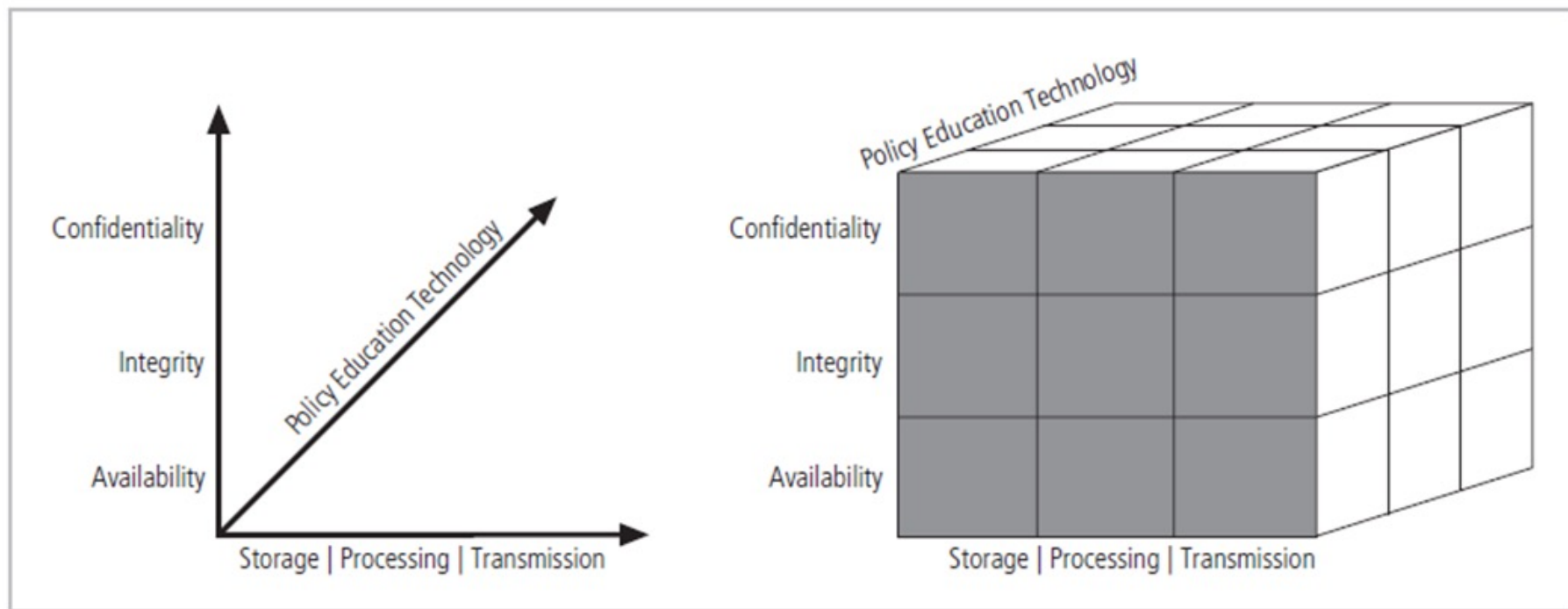
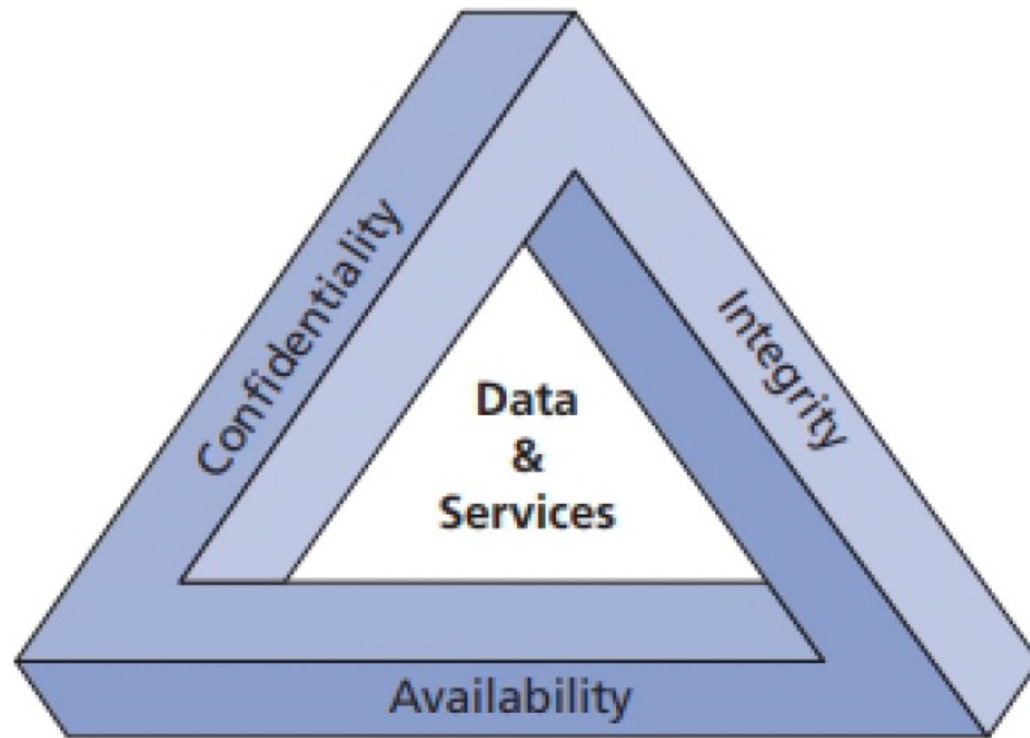


Figure 1-2 CNSS security model¹

Bộ ba C.I.A.



Tính bí mật - Confidentiality

- Tính bí mật là “Một thuộc tính của thông tin mô tả cách dữ liệu được bảo vệ khỏi tiết lộ hoặc phơi bày cho các cá nhân hay các hệ thống nếu không được phép”
- Bí mật có nghĩa là giới hạn quyền truy cập thông tin chỉ cho những người cần và ngăn chặn quyền truy cập của những người không cần
- Để bảo vệ tính bí mật của thông tin, các biện pháp được dùng:
 - Phân loại thông tin
 - Lưu trữ tài liệu (và dữ liệu) an toàn
 - Áp dụng các chính sách bảo mật chung
 - Giáo dục người quản lý thông tin (custodians) và người dùng
 - Mật mã (mã hoá)

Tính toàn vẹn - Integrity

- Tính toàn vẹn là "một thuộc tính của thông tin mô tả cách dữ liệu được toàn vẹn, đầy đủ và không bị gián đoạn"
- Tính toàn vẹn của thông tin bị đe dọa khi thông tin đó bị hư hỏng, phá hủy hoặc làm gián đoạn trạng thái xác thực của nó
- Hư hỏng có thể xảy ra khi thông tin đang được nhập, lưu trữ hoặc truyền đi

Tính khả dụng - Availability

- Tính khả dụng là "Một thuộc tính của thông tin mô tả cách dữ liệu có thể truy cập và được định dạng chính xác để sử dụng mà không bị can thiệp hoặc cản trở"
- Tính sẵn có của thông tin có nghĩa là người dùng, người hoặc hệ thống khác, có quyền truy cập vào thông tin đó ở định dạng có thể dùng được
- Tính khả dụng không có nghĩa là bất kỳ người dùng nào cũng có thể truy cập thông tin; thay vào đó, nó có nghĩa là nó có thể được truy cập khi cần thiết bởi người dùng *được cấp quyền (authorized)*

Quyền riêng tư - Privacy

- Quyền riêng tư là “trong ngữ cảnh an toàn thông tin, quyền của các cá nhân hoặc của các nhóm tự bảo vệ bản thân và thông tin của họ khỏi bị truy cập trái phép, cung cấp tính bí mật”
- Thông tin được thu thập, sử dụng và lưu trữ bởi một tổ chức chỉ được sử dụng cho các mục đích đã nêu với chủ sở hữu dữ liệu tại thời điểm nó được thu thập
- Trong ngữ cảnh này, quyền riêng tư không có nghĩa là tự do quan sát (thường được kết hợp là quyền tự do của thủ thể); nó có nghĩa là thông tin sẽ chỉ được sử dụng theo những cách được người đã cung cấp thông tin đó chấp thuận

Tổng hợp thông tin

- Nhiều tổ chức thu thập, trao đổi và bán thông tin cá nhân như một loại hàng hóa
- Ngày nay, có thể thu thập và kết hợp thông tin cá nhân từ nhiều nguồn khác nhau, được gọi là **tổng hợp thông tin - information aggregation**
- Tổng hợp thông tin dẫn đến việc dữ liệu có thể được sử dụng theo cách mà chủ sở hữu dữ liệu ban đầu không đồng ý hoặc thậm chí không biết

Nhận dạng - Identification

- Nhận dạng là “cơ chế kiểm soát truy cập theo đó các thực thể được xác minh sẽ được cấp quyền truy cập vào tài nguyên”
- Một hệ thống thông tin có khả năng nhận dạng khi nó có thể nhận ra người dùng cá nhân
- Nhận dạng (identification) và xác thực (authentication) rất cần để thiết lập cấp độ truy cập hoặc cấp độ ủy quyền cho một cá nhân
- Nhận dạng thường được thực hiện bằng tên người dùng (user name) hoặc các ID khác

Xác thực - Authentication

- Xác thực là “cơ chế kiểm soát truy cập yêu cầu xác nhận và xác minh danh tính có chủ đích (purported identity) của thực thể chưa được xác thực”
- Nó là tiến trình mà kiểm soát thiết lập xem người dùng hoặc hệ thống có danh tính như nó tuyên bố không
- Người dùng cá nhân có thể tiết lộ số nhận dạng cá nhân (PIN - personal identification number), mật khẩu (password hoặc passphrase) để xác thực danh tính của họ với hệ thống máy tính

Ủy quyền - Authorization

- Ủy quyền là “cơ chế kiểm soát truy cập thể hiện sự phù hợp của một thực thể đã được xác thực với danh mục các tài sản thông tin và các cấp độ truy cập tương ứng”
- Sau khi danh tính của người dùng được xác thực, ủy quyền xác định những gì người dùng (có thể là người hay máy tính) được cấp quyền một cách cụ thể và rõ ràng, chẳng hạn như truy cập, sửa đổi hoặc xóa nội dung của nội dung thông tin

Trách nhiệm giải trình - Accountability

- Trách nhiệm giải trình (accountability) là “cơ chế kiểm soát truy cập để bảo đảm mọi hành động trên hệ thống – được phép hoặc không được phép – có thể được quy cho một danh tính đã xác thực, còn được gọi là có khả năng kiểm tra (auditability)”
- Trách nhiệm giải trình thông tin xảy ra khi một biện pháp kiểm soát cung cấp sự đảm bảo rằng mọi hoạt động được thực hiện có thể được quy cho một người hoặc quy trình tự động cụ thể
- Trách nhiệm giải trình thường được kết hợp với nhật ký kiểm tra hệ thống (system audit logs)



Chương 01: Giới thiệu về Quản lý an toàn thông tin

CÁC KHÁI NIỆM CHÍNH TRONG AN TOÀN THÔNG TIN: NGUY CƠ (THREATS) VÀ TẤN CÔNG (ATTACKS)

Nghệ thuật Chiến tranh của Tôn Tử

“Bởi vậy ta nói: Ai biết địch, biết mình thì trăm trận không gặp nguy.

Kẻ không biết địch mà biết mình có lúc thắng, có lúc thua

Kẻ không biết địch, không biết mình sẽ gặp nguy hiểm trong mọi trận chiến”.

Để bảo vệ thông tin của tổ chức, bạn phải:

- biết chính mình; nghĩa là quen thuộc với các tài sản thông tin cần được bảo vệ và các hệ thống, cơ chế và phương pháp được sử dụng để lưu trữ, vận chuyển, xử lý và bảo vệ chúng; và
- biết các nguy cơ bạn phải đối mặt

Các khái niệm chính trong an toàn thông tin: Nguy cơ và Tấn công

- Một nguy cơ (threat) hay mối đe dọa thể hiện một rủi ro tiềm tàng đối với tài sản thông tin, trong khi một tấn công (attack) thể hiện một hành động đang chống lại tài sản đó và có thể dẫn đến tổn thất
- Các tác nhân nguy cơ có thể làm hỏng hoặc đánh cắp tài sản thông tin hay tài sản vật chất của tổ chức bằng cách khai thác (exploit) để tận dụng lỗ hổng bảo mật thiếu các biện pháp kiểm soát không có mặt hoặc có nhưng không hiệu quả
- Không giống như các nguy cơ luôn hiện hữu, các cuộc tấn công chỉ tồn tại khi một hành động cụ thể có thể gây ra tổn thất

Các khái niệm chính trong ATTT

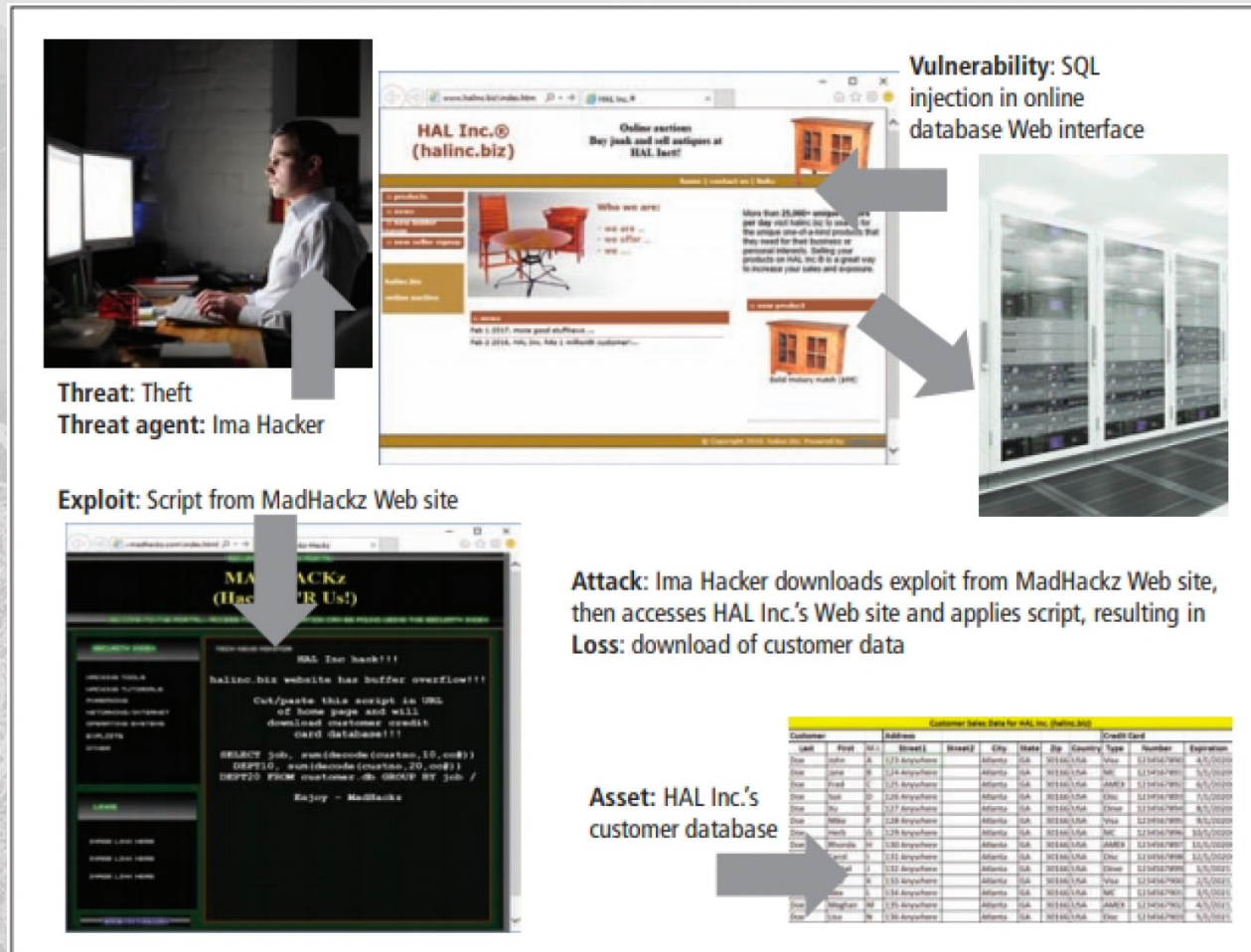


Figure 1-4 Key concepts in information security

Sources: The photo at top left is from © iStock.com/TommL. The photo at top right is from © iStock.com/nerminmuminovic.

12 Loại Nguy cơ trong ATTT

Category of Threat	Attack Examples
Compromises to intellectual property	Piracy, copyright infringement
Deviations in quality of service	Internet service provider (ISP), power, or WAN service problems
Espionage or trespass	Unauthorized access and/or data collection
Forces of nature	Fire, floods, earthquakes, lightning
Human error or failure	Accidents, employee mistakes
Information extortion	Blackmail, information disclosure
Sabotage or vandalism	Destruction of systems or information
Software attacks	Viruses, worms, macros, denial of service
Technical hardware failures or errors	Equipment failure
Technical software failures or errors	Bugs, code problems, unknown loopholes
Technological obsolescence	Antiquated or outdated technologies
Theft	Illegal confiscation of equipment or information

Table 1-1 The 12 categories of threats to information security⁵

© Cengage Learning 2016.

Xâm phạm Sở hữu trí tuệ

- Sở hữu trí tuệ (IP - Intellectual property) có thể là bí mật thương mại (trade secrets), bản quyền (copyrights), nhãn hiệu (trademarks) và bằng sáng chế (patents)
- IP được bảo vệ bằng luật bản quyền và các luật khác, nhằm ghi nhận tác giả hoặc nguồn gốc, và yêu cầu phải xin phép khi sử dụng như được quy định trong các luật
- Việc chiếm đoạt trái phép quyền SHTT tạo thành mối nguy cơ đối với an toàn thông tin
- Danh mục này bao gồm hai lĩnh vực chính:
 - Vi phạm bản quyền phần mềm
 - Bảo vệ bản quyền và đăng ký người dùng

Sai lệch về Chất lượng Dịch vụ - Deviations in Quality of Service

- Hệ thống thông tin của một tổ chức phụ thuộc vào sự vận hành thành công của nhiều hệ thống hỗ trợ phụ thuộc lẫn nhau, bao gồm lưới điện, mạng dữ liệu và viễn thông, nhà cung cấp phụ tùng, nhà cung cấp dịch vụ và thậm chí cả nhân viên lao công và người chở rác
- Bất kỳ hệ thống hỗ trợ nào trong số này đều có thể bị gián đoạn do thời tiết khắc nghiệt, bệnh tật của nhân viên hoặc các sự kiện không lường trước khác
- Sự bất thường trong dịch vụ Internet, thông tin liên lạc và nguồn cung cấp điện có thể ảnh hưởng đáng kể đến tính khả dụng của thông tin và hệ thống
- Các danh mục phụ của mỗi nguy cơ này bao gồm:
 - Các vấn đề về thông tin liên lạc và nhà cung cấp dịch vụ khác
 - Bất thường về điện năng

Gián điệp (Espionage) và Xâm nhập (Trespass)

- Khi một người không được ủy quyền nhưng có quyền truy cập vào thông tin mà tổ chức đang cố bảo vệ, hành động đó được phân loại là gián điệp hoặc xâm nhập
- Kẻ tấn công có thể sử dụng nhiều phương pháp khác nhau để truy cập thông tin được lưu trữ trong hệ thống thông tin
- Một số kỹ thuật thu thập thông tin là hợp pháp — như sử dụng trình duyệt Web thực hiện nghiên cứu thị trường
 - Các kỹ thuật hợp pháp này được gọi chung là trí tuệ cạnh tranh (competitive intelligence)
- Khi những người thu thập thông tin sử dụng các kỹ thuật vượt qua ngưỡng (threshold) luật pháp hoặc đạo đức, họ đang thực hiện hoạt động gián điệp công nghiệp

Gián điệp (Espionage) và Xâm nhập (Trespass)

- Trong thế giới thực, một tin tặc thường dành nhiều thời giờ để kiểm tra loại và cấu trúc của các hệ thống mục tiêu; sử dụng kỹ năng, mảnh khảnh và/hoặc gian lận để vượt qua các kiểm soát được đặt trên thông tin
- Tin tặc sở hữu một loạt các cấp độ kỹ năng, giống như với hầu hết kỹ thuật viên / kỹ sư công nghệ
 - Tuy nhiên, hầu hết các tin tặc được nhóm thành hai loại chung - tin tặc chuyên nghiệp và tin tặc mới
- Khi kẻ tấn công giành được quyền truy cập vào hệ thống, bước tiếp theo là tăng đặc quyền (leo thang đặc quyền - privilege escalation)
 - Hầu hết các tài khoản được liên kết với hệ thống chỉ có quyền “sử dụng” tối thiểu, kẻ tấn công cần các đặc quyền quản trị hoặc quyền “root”

Gián điệp (Espionage) và Xâm nhập (Trespass)

- Tấn công bằng mật khẩu (Password Attack): Các cuộc tấn công bằng mật khẩu thuộc loại gián điệp hoặc xâm nhập giống như việc chọn khóa bị phá vỡ và xâm nhập
- Cố gắng đoán hoặc tính toán ngược lại mật khẩu thường được gọi là bẻ khóa
- Có một số cách tiếp cận thay thế để bẻ khóa mật khẩu:
 - Tấn công vét cạn (Brute Force Attack) - Ứng dụng thử mọi tổ hợp mật khẩu có thể tạo ra
 - Tấn công mật khẩu dùng từ điển (Dictionary password attack) – một kiểu khác của tấn công vét cạn, thu hẹp trường tấn công bằng cách dùng từ điển gồm những mật khẩu thông dụng và có kèm theo thông tin liên quan đến đích tấn công
 - Dùng Rainbow Tables—Một cơ sở dữ liệu gồm các giá trị băm (hash) và các giá trị tương đương không được mã hóa của chúng để so sánh với một tệp mật khẩu được mã hóa
 - Tấn công mật khẩu dùng kỹ thuật xã hội (Social Engineering Password) - kẻ tấn công đóng giả là nhân viên có thể cố gắng truy cập vào thông tin hệ thống yêu cầu các nhân viên khác cung cấp tên người dùng và mật khẩu của họ, sau đó sử dụng thông tin để giành quyền truy cập vào hệ thống tổ chức

Tác động của Thiên nhiên (Forces of Nature)

- Tác động của thiên nhiên có thể đưa đến một số nguy cơ nguy hiểm nhất vì chúng thường xảy ra với ít cảnh báo và nằm ngoài tầm kiểm soát
- Vì không thể tránh được những nguy cơ này, các tổ chức phải thực hiện các biện pháp kiểm soát để hạn chế thiệt hại và chuẩn bị các kế hoạch dự phòng để duy trì hoạt động liên tục
- Trường hợp bất khả kháng hoặc vượt quá mức độ là tác động của thiên nhiên cũng như rối loạn dân sự và các hành động chiến tranh
- Hầu hết các tác động của thiên nhiên chỉ có thể được giảm thiểu thông qua bảo hiểm, dù rằng thiết kế và bố trí cơ sở vật chất có cẩn thận đi nữa cũng chỉ có thể làm giảm khả năng thiệt hại

Tác động của Thiên nhiên (Forces of Nature)

Một số loại tác động của thiên nhiên điển hình gồm:

- Lửa
- Lụt
- Động đất
- Sét
- Lở đất
- Lốc xoáy hoặc gió bão dữ dội
- Bão, áp thấp nhiệt đới
- Sóng thần (Tsunami)
- Xả tĩnh điện (ESD)
- Ô nhiễm bụi

Lỗi hoặc sai sót của con người

- Mục này gồm các hành vi được thực hiện không có chủ đích hoặc mục đích xấu hoặc do không biết của người dùng được uỷ quyền
- Khi con người sử dụng hệ thống thông tin sẽ xảy ra những sai lầm
- Các lỗi tương tự xảy ra khi con người không tuân thủ chính sách đã thiết lập
- Thiếu kinh nghiệm, đào tạo không đúng cách và giả định không chính xác chỉ là một vài điều có thể gây ra lỗi hoặc thất bại cho con người
- Một trong những mối đe dọa lớn nhất đối với an toàn thông tin của một tổ chức là nhân viên của chính tổ chức đó, vì họ là những tác nhân đe dọa gần nhất với thông tin
- Lỗi hoặc sai sót của con người thường có thể được ngăn chặn bằng đào tạo, liên tục tăng cường nhận thức,
- và cuối cùng là ... kiểm soát và kiểm soát

Lỗi hoặc sai sót của con người

- Một số tấn công vào lỗi hoặc sai sót của con người bao gồm:
 - Kỹ thuật xã hội (Social Engineering)
 - Gian lận phí trả trước (Advance-fee Fraud)
 - Câu nhử (Phishing)
 - Thao túng URL (URL Manipulation)
 - Giả mạo trang web (Web site forgery)
 - Câu nhử nhắm đích (Spear Phishing)
 - Mạo danh qua điện thoại (Pretexting)

Tống tiền Thông tin (Information Extortion)

- Tống tiền thông tin, còn gọi là tống tiền qua mạng (cyberextortion), là phổ biến trong việc đánh cắp số thẻ tín dụng
- Các cuộc tấn công tống tiền thông tin gần đây liên quan đến các dạng phần mềm độc hại chuyên biệt được gọi là ransomware - mã hóa dữ liệu của người dùng và yêu cầu trả tiền để được giải mã

Phá hoại (Sabotage / Vandalism)

- Loại nguy cơ này liên quan đến việc cố ý phá hoại (sabotage) hệ thống máy tính hoặc công việc kinh doanh hoặc các hành vi phá hoại (vandalism) nhằm phá hủy tài sản hoặc làm hỏng hình ảnh của một tổ chức
- Những hành vi này có thể bao gồm từ phá hoại nhỏ của nhân viên đến phá hoại có tổ chức chống lại một tổ chức
- Hành vi phá hoại một trang web có thể làm xói mòn niềm tin của người tiêu dùng, làm giảm doanh số bán hàng, và danh tiếng của tổ chức
- Chủ nghĩa hành động trong thời đại kỹ thuật số:
 - Chủ nghĩa hành động trực tuyến (Online Activism)
 - Khủng bố mạng (Cyberterrorism) and Chiến tranh mạng (Cyberwarfare)
 - Chủ nghĩa hành động trực tuyến tích cực (Positive Online Activism)

Tấn công phần mềm

- Các cuộc tấn công phần mềm có chủ ý xảy ra khi một cá nhân hoặc nhóm thiết kế và triển khai phần mềm để tấn công hệ thống
- Tấn công kiểu này có thể gồm các phần mềm được chế tạo đặc biệt mà kẻ tấn công lừa người dùng cài đặt trên hệ thống của họ
- Phần mềm này có thể được sử dụng để lấn át khả năng xử lý của các hệ thống trực tuyến hoặc để truy cập vào các hệ thống được bảo vệ bằng các phương thức ẩn

Tấn công phần mềm

- Mã độc (Malware) bao gồm virus, worms, Trojan horses, các nguy cơ và lừa bịp đa hình (polymorphic)
- Cửa hậu (back doors), cửa bẫy (trap doors), và các móc nối cho bảo trì (maintenance hooks)
- Các tấn công từ chối dịch vụ (DoS (Denial-of-service) và từ chối dịch vụ phân tán (DDoS - Distributed DoS)
- Tấn công email như thư rác (spam), bom thư (mail bombs) và các tấn công kỹ thuật xã hội
- Các cuộc tấn công đánh chặn thông tin liên lạc như trình bắt gói tin (packet sniffers), giả mạo (spoofing), chuyển hướng lưu lượng web (pharming) và tấn công trung gian (man-in-the-middle) như tấn công chiếm TCP hoặc chiếm quyền điều khiển phiên

Lỗi kỹ thuật phần cứng

- Hư hỏng hoặc lỗi phần cứng xảy ra khi nhà sản xuất phân phối thiết bị có chứa một lỗi đã biết hoặc chưa biết
- Những khiếm khuyết này có thể khiến hệ thống hoạt động ngoài các thông số mong đợi, dẫn đến dịch vụ không đáng tin cậy hoặc thiếu tính khả dụng
- Theo thuật ngữ phần cứng, các lỗi được đo bằng thời gian giữa các lỗi trung bình (MTBF - mean time between failure) và thời gian lỗi trung bình (MTTF - mean time to failure)
 - MTBF cho rằng mặt hàng có thể được sửa chữa hoặc trả lại dịch vụ, MTTF cho rằng mặt hàng đó phải được thay thế
 - Từ quan điểm sửa chữa, $MTBF = MTTF + MTTD + MTTR$, trong đó MTTD (mean time to diagnose) là thời gian chẩn đoán trung bình và MTTR (mean time to repair) là thời gian sửa chữa trung bình

Lỗi kỹ thuật phần mềm

- Lỗi kỹ thuật phần mềm: một lượng lớn mã máy tính được viết, gỡ lỗi, phát hành và bán trước khi tất cả các lỗi (bug) của chúng được phát hiện và giải quyết
- Đôi khi, sự kết hợp của một số phần mềm và phần cứng làm lộ ra các lỗi mới, từ lỗi đến các tình trạng lỗi chưa được kiểm tra
- Đôi khi những lỗi (bug) này không phải là sai sót, mà là những lối tắt (shortcut) có chủ đích do các lập trình viên để lại vì những lý do lành tính để bỏ qua kiểm tra bảo mật - được gọi là cửa bẫy (trap door)
- Trong số các trang web theo dõi lỗi phổ biến nhất là Bugtraq (được host bởi Security Focus), cung cấp thông tin cập nhật từng phút về các lỗ hổng bảo mật mới nhất cũng như một kho lưu trữ đầy đủ về các lỗi trong quá khứ.

Lỗi kỹ thuật phần mềm

- Dự án Bảo mật ứng dụng Web nguồn mở OWASP (Open Web Application Security Project) liệt kê “10 rủi ro bảo mật ứng dụng web nghiêm trọng nhất” năm 2013:
 - Tiêm nhiễm (Injection)
 - Quản lý xác thực và phiên bị hỏng (Broken authentication and session management)
 - Kịch bản xuyên trang XSS (Cross-site scripting)
 - Tham chiếu đối tượng trực tiếp không an toàn (Insecure direct object references)
 - Cấu hình bảo mật sai (Security misconfiguration)
 - Tiết lộ dữ liệu nhạy cảm (Sensitive data exposure)
 - Thiếu kiểm soát truy cập cấp chức năng (Missing function level access control)
 - Giả mạo yêu cầu xuyên trang CRSF (Cross-site request forgery)
 - Sử dụng các thành phần có lỗ hổng đã biết (Using components with known vulnerabilities)
 - Chuyển hướng và chuyển tiếp chưa được xác thực (Unvalidated redirects and forwards)

Lỗi của bảo mật phần mềm

Lỗi Ứng dụng Web

- SQL Injection
- Web Server-Related Vulnerabilities
- Web Client-Related Vulnerabilities (XSS)
- Dùng các URL ma thuật (magic URL), Cookie có thể đoán trước và các trường biểu mẫu ẩn (Hidden Form Fields)

Lỗi Thực thi

- Tràn bộ đệm (Buffer Overruns)
- Format String Problems
- Tràn số (Integer Overflows)
- Catching Exceptions
- Command Injection
- Failure to Handle Errors Correctly
- Information Leakage
- Race Conditions
- Poor Usability
- Not Updating Easily
- Executing Code with Too Much Privilege
- Failure to Protect Stored Data
- The Sins of Mobile Code

Lỗi của bảo mật phần mềm

Lỗi mật mã

- Dùng các hệ thống dựa trên mật mã yếu
- Số ngẫu nhiên yếu (Weak Random Numbers)
- Sử dụng mật mã sai

Lỗi mạng

- Không bảo vệ được lưu lượng mạng
- Sử dụng PKI không đúng cách, nhất là SSL
- Phân giải tên mạng tin cậy

Công nghệ lỗi thời - Technological Obsolescence

- Cơ sở hạ tầng cũ kỹ hoặc lỗi thời có thể dẫn đến các hệ thống không đáng tin cậy
- Cấp quản lý phải nhận ra rằng khi công nghệ trở nên lỗi thời, có nguy cơ mất tính toàn vẹn của dữ liệu do các cuộc tấn công
- Một cách lý tưởng, lập kế hoạch phù hợp của cấp quản lý sẽ ngăn chặn công nghệ trở nên lỗi thời, nhưng nếu sự lỗi thời đã rõ ràng thì ban quản lý phải hành động ngay
- Trường hợp điển hình nhất về sự lỗi thời của công nghệ trong các năm gần đây là Windows XP của Microsoft

Trộm cắp - Theft

- Giá trị của thông tin bị giảm đi khi :
 - Sao chép mà chủ sở hữu không biết
 - Trộm cắp vật lý có thể được kiểm soát dễ dàng bằng nhiều biện pháp, từ cửa khoá đến các nhân viên an ninh được đào tạo và lắp đặt hệ thống báo động
 - Tuy nhiên, trộm cắp điện tử là vấn đề phức tạp hơn để quản lý và kiểm soát
 - Trộm cắp thường là một loại chồng lấn với các cuộc tấn công phần mềm, gián điệp hoặc xâm nhập, tổng tiền thông tin và xâm phạm quyền sở hữu trí tuệ

The background of the slide is a faded photograph of a modern architectural building with a curved facade and large glass windows. In the foreground, there is a park-like setting with a prominent weeping willow tree on the left, several outdoor tables and chairs, and a paved path leading into the distance.

Chương 01: Giới thiệu Quản lý bảo an toàn thông tin

QUẢN LÝ LÀ GÌ?

Quản lý là gì?

- Quản lý là tiến trình đạt được các mục tiêu sử dụng các nguồn lực đã cho
- Người quản lý là thành viên của tổ chức được giao nhiệm vụ điều phối và quản lý các nguồn lực, điều phối việc hoàn thành nhiệm vụ và đảm nhiệm nhiều vai trò cần thiết để hoàn thành các mục tiêu mong muốn

Vai trò Quản lý

- **Vai trò thông tin:** thu thập, xử lý, và sử dụng thông tin có thể ảnh hưởng đến việc hoàn thành mục tiêu
- **Vai trò giữa các cá nhân:** Tương tác với cấp trên, cấp dưới, các bên liên quan bên ngoài và các bên khác có ảnh hưởng hoặc bị ảnh hưởng bởi việc hoàn thành nhiệm vụ
- **Vai trò quyết định:** lựa chọn trong số các phương pháp tiếp cận thay thế và giải quyết các xung đột, tình huống khó xử hoặc thách thức

Sự khác biệt giữa Lãnh đạo và Quản lý

- Một nhà lãnh đạo ảnh hưởng đến nhân viên để họ sẵn sàng hoàn thành các mục tiêu:
 - Người đó được kỳ vọng sẽ lãnh đạo bằng gương và thể hiện những đặc điểm cá nhân khiến người khác mong muốn noi theo
 - Nói cách khác, lãnh đạo cung cấp mục đích, định hướng và động lực cho những người làm theo
- Bằng cách so sánh, một nhà quản lý quản lý các nguồn lực của tổ chức:
 - Người đó tạo ngân sách, ủy quyền chi tiêu và thuê nhân viên
- Các nhà quản lý hiệu quả có thể là những nhà lãnh đạo hiệu quả

Các loại hành vi của Lãnh đạo

- Có 3 loại hành vi cơ bản của lãnh đạo:
 - chuyên quyền,
 - dân chủ, và
 - thoải mái (laissez-faire)

Các đặc tính quản lý

- Hai cách tiếp cận cơ bản để quản lý là:
 - Lý thuyết quản lý truyền thống sử dụng các nguyên tắc cốt lõi về lập kế hoạch, tổ chức, bố trí nhân sự, chỉ đạo và kiểm soát (POSDC - planning, organizing, staffing, directing, and controlling)
 - Lý thuyết quản lý phổ biến phân loại các nguyên tắc quản lý thành lập kế hoạch, tổ chức, lãnh đạo và kiểm soát (POLC - planning, organizing, leading, and controlling)

Liên kết Lập Kế hoạch-Kiểm soát

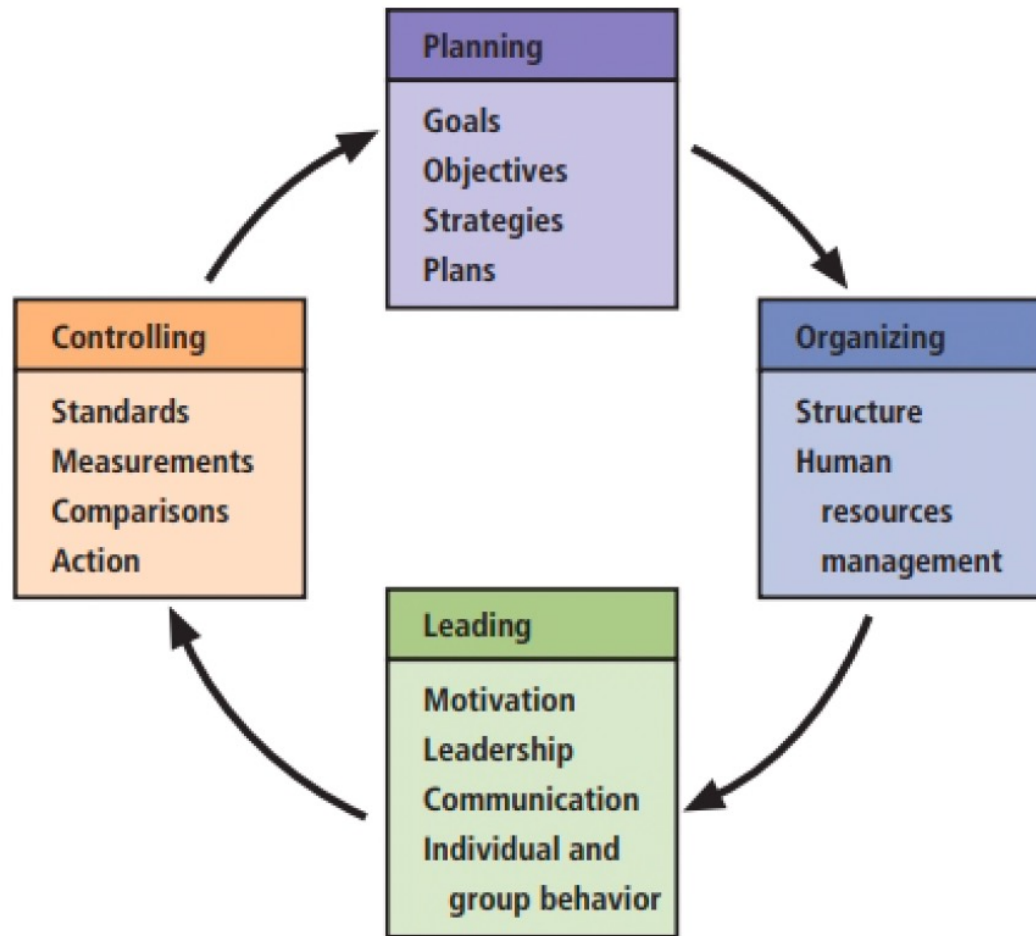
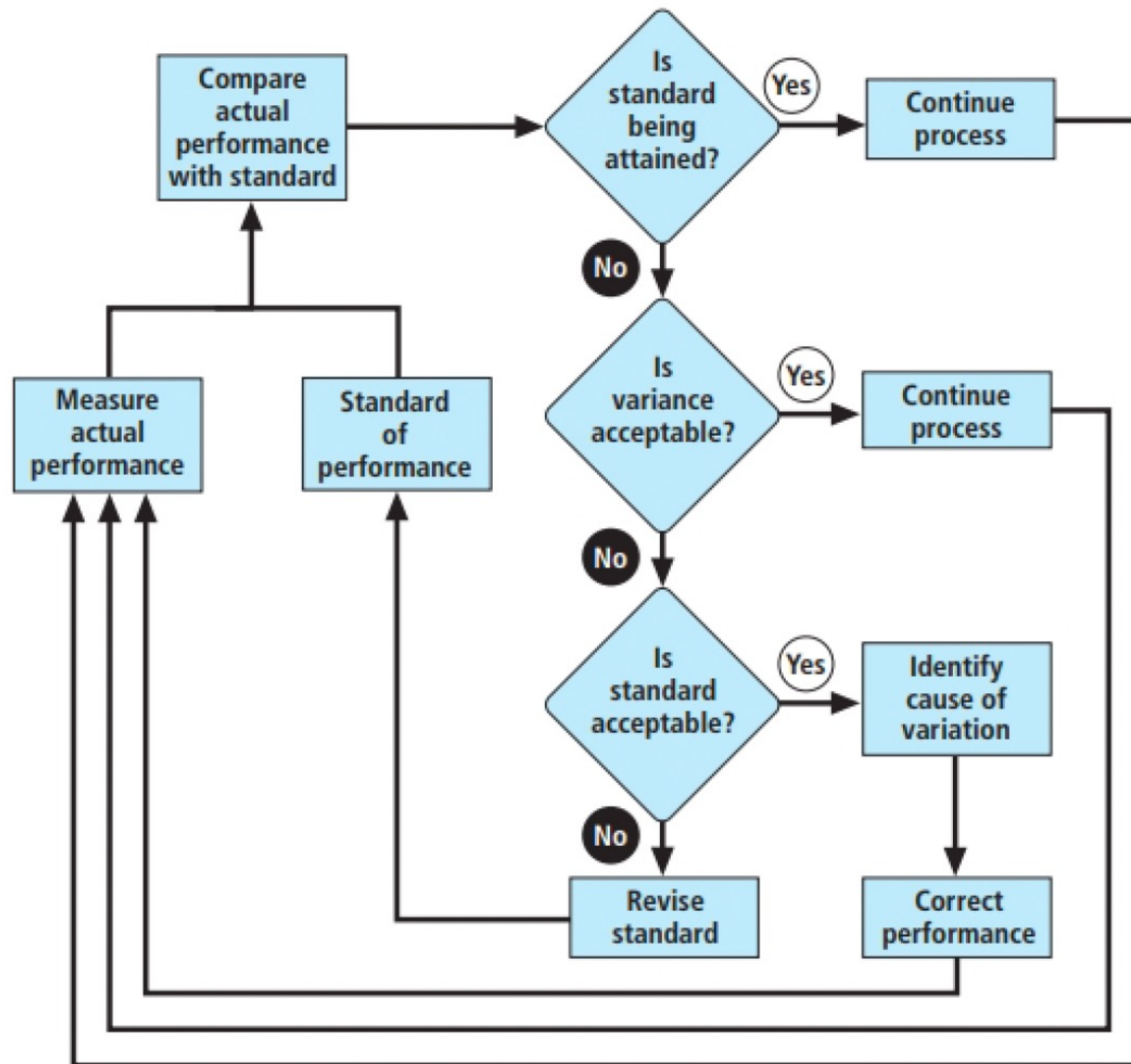


Figure 1-7 The planning-controlling link

Lập kế hoạch

- Quá trình phát triển, tạo và thực hiện các chiến lược để hoàn thành các mục tiêu được gọi là lập kế hoạch:
 - Hoạch định chiến lược — xảy ra ở các cấp cao nhất của tổ chức và trong một khoảng thời gian dài, thường là năm năm trở lên
 - Lập kế hoạch chiến thuật — tập trung vào việc lập kế hoạch sản xuất và tích hợp các nguồn lực của tổ chức ở cấp độ bên dưới toàn bộ doanh nghiệp và trong một thời gian trung gian (chẳng hạn như một đến năm năm)
 - Lập kế hoạch hoạt động — tập trung vào các hoạt động hàng ngày của các nguồn lực cục bộ, diễn ra trong hiện tại hoặc ngắn hạn

Tiến trình kiểm soát

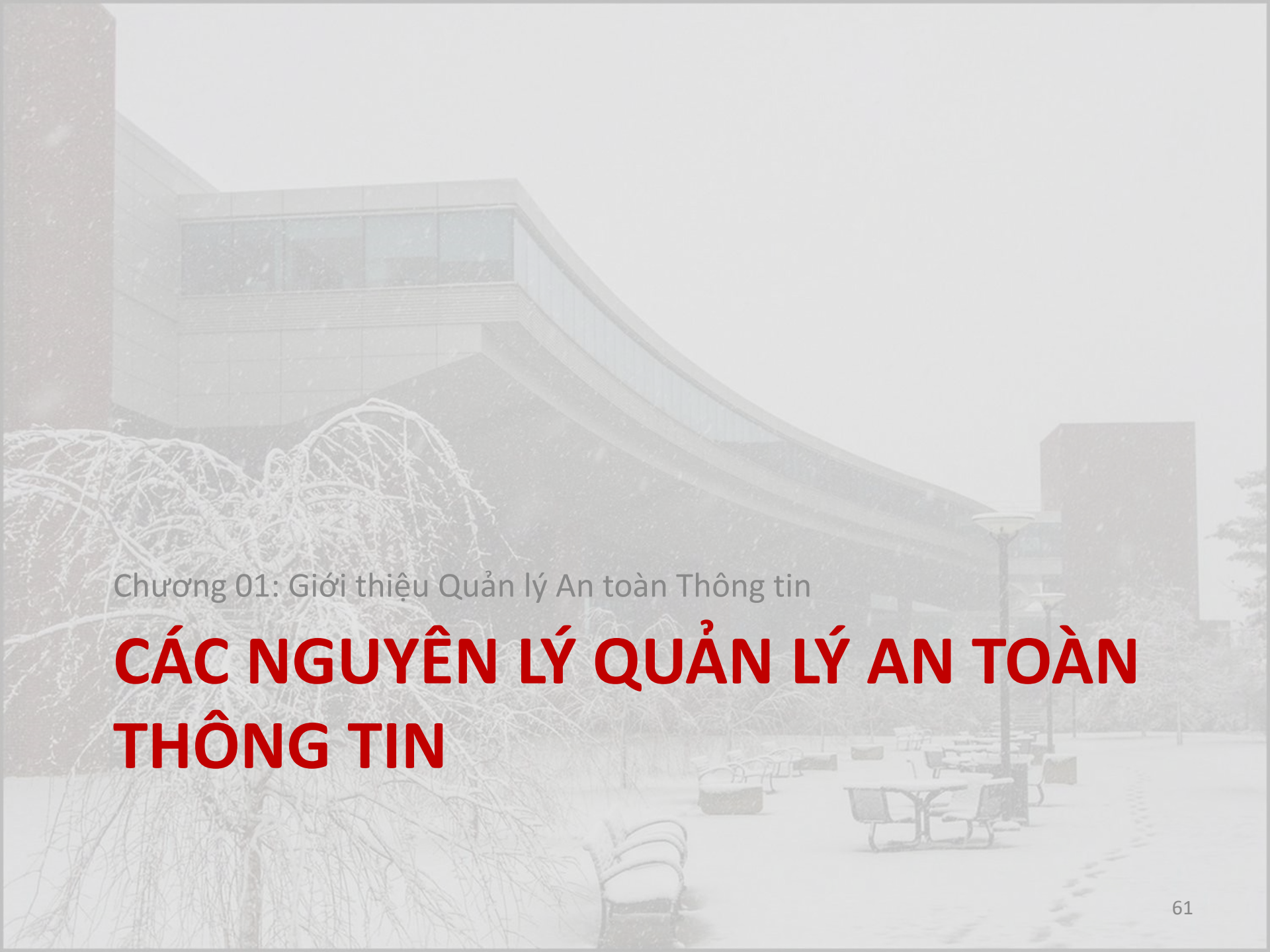


Quản trị - Governance

- Quản trị là “tập hợp các trách nhiệm và thông lệ được thực hiện bởi hội đồng quản trị và ban điều hành với mục tiêu đưa ra định hướng chiến lược, đảm bảo rằng các mục tiêu đạt được, xác định rằng rủi ro được quản lý một cách thích hợp và xác minh rằng các nguồn lực của doanh nghiệp được sử dụng một cách có trách nhiệm”
- Quản trị nhấn mạnh việc nâng tầm quan trọng của ATTT (InfoSec) lên các cấp cao nhất của tổ chức và cung cấp cho nó một mức độ quản lý thích hợp

Giải quyết vấn đề

- Bước 1: Nhận diện và Xác định Vấn đề
- Bước 2: Thu thập dữ kiện và đưa ra giả định
- Bước 3: Phát triển các giải pháp khả thi
- Bước 4: Phân tích và so sánh các giải pháp khả thi (phân tích khả thi)
- Bước 5: Chọn, Thực thi, và Đánh giá giải pháp



Chương 01: Giới thiệu Quản lý An toàn Thông tin

CÁC NGUYÊN LÝ QUẢN LÝ AN TOÀN THÔNG TIN

Các nguyên tắc Quản lý ATTT

- Các chức năng duy nhất của quản lý an toàn thông tin được biết đến là 6P:
 - Planning (lập kế hoạch)
 - Policy (Chính sách)
 - Programs (Chương trình)
 - Protection (Bảo vệ)
 - People (Con người)
 - Project Management (Quản lý dự án)

Lập kế hoạch ATTT

- Lập kế hoạch như một phần của quản lý ATTT là một mở rộng của mô hình lập kế hoạch cơ bản được thảo luận trước đó trong chương này
- Bao gồm trong mô hình lập kế hoạch ATTT là các hoạt động cần thiết để hỗ trợ thiết kế, tạo và thực hiện các chiến lược an toàn thông tin, vì chúng tồn tại trong môi trường lập kế hoạch CNTT

Lập kế hoạch ATTT

- Một số loại lập kế hoạch ATTT:
 - kế hoạch phản ứng sự cố (incident response planning)
 - kế hoạch duy trì hoạt động liên tục (business continuity planning)
 - kế hoạch phục hồi thảm họa (disaster recovery planning)
 - kế hoạch chính sách (policy planning)
 - kế hoạch con người (personnel planning)
 - Kế hoạch triển khai công nghệ (technology rollout planning)
 - Kế hoạch quản lý rủi ro (risk management planning) và
 - Kế hoạch chương trình an toàn (security program planning) bao gồm đào tạo, huấn luyện và nhận thức

Lập kế hoạch ATTT

- Bao gồm trong mô hình lập kế hoạch ATTT là các hoạt động cần thiết để hỗ trợ thiết kế, tạo và thực hiện các chiến lược ATTT trong môi trường lập kế hoạch của tất cả các đơn vị tổ chức, gồm cả CNTT
- Bởi vì các kế hoạch chiến lược ATTT không chỉ phải hỗ trợ việc sử dụng CNTT và bảo vệ tài sản thông tin mà còn của toàn bộ tổ chức, nên CISO bắt buộc phải hợp tác chặt chẽ với tất cả các nhà quản lý cấp cao trong việc phát triển chiến lược ATTT

Chính sách

- Chính sách là “một tập các hướng dẫn của tổ chức quy định hành vi nhất định trong tổ chức”
- Trong ATTT, có ba loại chính sách chung:
 - Chính sách an toàn thông tin doanh nghiệp (EISP - Enterprise information security policy)
 - Chính sách an toàn cho một vấn đề cụ thể (ISSP - Issue-specific security policy)
 - Các chính sách an toàn cho một hệ thống cụ thể (SysSP - System-specific policies)

Chương trình

- Các hoạt động ATTT được quản lý cụ thể như các thực thể riêng biệt
- Chương trình đào tạo và nâng cao nhận thức về an toàn (SETA - security education training and awareness) là một trong những thực thể như vậy
- Các chương trình khác có thể có gồm chương trình bảo mật vật lý, tiếp cận vật lý, cổng, bảo vệ, v.v.

Bảo vệ

- Chức năng bảo vệ được thực hiện thông qua một tập hợp các hoạt động quản lý rủi ro, bao gồm đánh giá và kiểm soát rủi ro, cũng như các cơ chế, công nghệ và công cụ bảo vệ
- Mỗi cơ chế này thể hiện một số khía cạnh của việc quản lý các biện pháp kiểm soát cụ thể trong kế hoạch an toàn thông tin tổng thể

Con người

- Con người là liên kết quan trọng nhất trong chương trình an toàn thông tin
- Lĩnh vực này của ATTT bao gồm nhân viên bảo mật và an toàn của nhân viên, cũng như các khía cạnh của chương trình SETA đã đề cập

Dự án

- Thành phần cuối cùng là áp dụng kỷ luật quản lý dự án cho tất cả các yếu tố của chương trình an toàn thông tin
- Quản lý dự án liên quan đến việc xác định và kiểm soát các nguồn lực được áp dụng cho dự án, cũng như đo lường tiến độ và điều chỉnh quá trình khi tiến độ đạt được mục tiêu

Quản lý dự án

- **An toàn thông tin là một quá trình**, không phải là một dự án, tuy nhiên, mỗi thành phần của chương trình an toàn thông tin phải được quản lý như một dự án, ngay cả khi chương trình tổng thể đang diễn ra
- Làm thế nào để bảo mật thông tin cho cả quá trình và dự án? Trên thực tế, nó là một chuỗi liên tục hoặc một chuỗi các dự án
- Một số khía cạnh của bảo mật thông tin không dựa trên dự án; đúng hơn, chúng là các quy trình được quản lý (hoạt động) và đang diễn ra

Tóm lược

- Bởi vì các doanh nghiệp và công nghệ đã trở nên linh hoạt hơn, khái niệm hẹp hơn về bảo mật máy tính đã được thay thế bằng khái niệm rộng hơn của bảo mật thông tin / an toàn thông tin
- Từ quan điểm của ATTT, các tổ chức thường có ba cộng đồng quan tâm: các nhà quản lý và chuyên gia ATTT; các nhà quản lý và chuyên gia CNTT; và các nhà quản lý và chuyên gia phi kỹ thuật
- Bộ ba C.I.A. dựa trên ba đặc điểm mong muốn của thông tin: tính bí mật, tính toàn vẹn và tính khả dụng
- Để đưa ra quyết định đúng đắn về an toàn thông tin, cấp quản lý phải được thông báo về các nguy cơ đối với con người, ứng dụng, dữ liệu và hệ thống thông tin của mình

Tóm lược (tiếp)

- Các mối đe dọa hoặc nguy hiểm mà con người, thông tin và hệ thống của tổ chức phải đối mặt thuộc các loại chung sau:
 - Xâm phạm sở hữu trí tuệ
 - Chênh lệch về chất lượng dịch vụ
 - Gián điệp hoặc xâm nhập
 - Tác động của thiên nhiên
 - Lỗi hoặc sai sót của con người
 - Tổng tiền thông tin
 - Phá hoại có chủ định hoặc không chủ ý
 - Tấn công phần mềm
 - Hư hỏng hoặc lỗi kỹ thuật phần cứng
 - Hư hỏng hoặc lỗi kỹ thuật phần mềm
 - Công nghệ lỗi thời
 - Trộm cắp

Tóm lược (tiếp)

- Tấn công là một hành động cố ý lợi dụng lỗ hổng để xâm nhập hệ thống được kiểm soát. Nó được thực hiện bởi một tác nhân đe dọa gây thiệt hại hoặc đánh cắp thông tin hoặc tài sản vật chất của một tổ chức. Lỗ hổng bảo mật là một điểm yếu được xác định trong một hệ thống được kiểm soát, nơi thiếu các biện pháp kiểm soát hoặc có nhưng không hiệu quả
- Các phương pháp phát triển phần mềm kém có thể gây ra rủi ro đáng kể, nhưng bằng cách phát triển các phương pháp phát triển hợp lý, kiểm soát thay đổi và đảm bảo chất lượng vào quy trình, chất lượng phần mềm tổng thể và hiệu suất bảo mật của phần mềm có thể được nâng cao
- Ở dạng đơn giản nhất, quản lý là quá trình đạt được các mục tiêu bằng cách sử dụng các nguồn lực
- Sự khác biệt quan trọng giữa nhà lãnh đạo và nhà quản lý là nhà lãnh đạo ảnh hưởng đến nhân viên để họ sẵn sàng hoàn thành các mục tiêu, trong khi người quản lý tạo ngân sách, ủy quyền chi tiêu và thuê nhân viên

Tóm lược (tiếp)

- Cách tiếp cận truyền thống đối với lý thuyết quản lý sử dụng các nguyên tắc cốt lõi của lập kế hoạch, tổ chức, biên chế, chỉ đạo và kiểm soát (POSDC). Một cách tiếp cận khác đối với lý thuyết quản lý phân loại các nguyên tắc quản lý thành: lập kế hoạch, tổ chức, lãnh đạo và kiểm soát (POLC)
- Quá trình phát triển, tạo và thực hiện các chiến lược để hoàn thành các mục tiêu được gọi là “lập kế hoạch”. Có ba cấp độ lập kế hoạch: chiến lược, chiến thuật và hoạt động
- Quản lý ATTT hoạt động giống như tất cả các đơn vị quản lý khác, nhưng mục đích và mục tiêu của nhóm quản lý ATTT khác nhau ở chỗ họ tập trung vào hoạt động an toàn của tổ chức

Bài tập

1. Assume that a security model is needed to protect information used in the class you are taking- say, the information in your course's learning management system. Use the CNSS model to identify each of the 27 cells needed for complete information protection. Write a brief statement that explains how you would address the components represented in each of the 27 cells.
2. Consider the information stored in your personal computer. Do you currently have information stored in your computer that is critical to your personal life? If that information became compromised or lost, what effect would it have on you?
3. Using the Web, research Stuxnet. When was it discovered? What kind of systems does it target? Who created it and what is it used for?

Bài tập

4. Search the Web for “The Official Phreaker's Manual.” What information in this manual might help a security administrator to protect a communications system?
5. The chapter discussed many threats and vulnerabilities to information security. Using the Web, find at least two other sources of information about threats and vulnerabilities. Begin with *www.securityfocus.com* and use a keyword search on “threats.”
6. Using the categories of threats mentioned in this chapter and the various attacks described, review several current media sources and identify examples of each threat.

Closing Case

Charlie and Iris met for a working lunch.

“First thing you need to do,” Charlie told Iris, “is gain some consensus from your higher management to fund a new position for a security analyst. Then fill it by finding someone who knows the security skills but is primarily skilled in project management. Or find a strong security analyst and send them off for PM training.”

“Why so?” Iris asked.

“A good project manager can help the entire team learn how to manage all the security projects to keep you from getting overwhelmed with deadlines and deliverables,” Charlie said, smiling. “A good PM can make your operations proactive rather than reactive.”

“That sounds good,” Iris replied. “What else do I need to know?”

Discussion Questions

1. Based on your reading of the chapter and what you now know about the issues, list at least three other things Charlie could recommend to Iris.
2. What do you think is the most important piece of advice Charlie gave Iris? Why?

Ethical Decision Making

Assume that Charlie then tells Iris, "I have a friend who runs a placement service and can find you exactly the right person for this position. Once you have the job posted, you can have them help you fill it. If they find you a great candidate and the placement is made, I will split the finder's fee with you."

Iris knows that her company may pay as much as half a year's salary for the placement services needed for such a hire. Charlie's friend is likely to pay him a substantial finder's fee if Iris awards the placement contract to them and someone gets placed. If she can get a good employee and a little extra money on the side, everyone wins.

However, Iris is not comfortable with such an arrangement, and she is pretty sure it is against company policy.

If this comes to pass, is Charlie doing anything illegal? Is Iris? What is ethically wrong with Charlie's proposal?